

Dependency Health Report — vulnerable-invoice-service

Generated: 2026-06-12T07:05:00Z | Health Score: **15 / 100** Grade D — action required | Trend: 0 → 15 (+15) vs. baseline

Executive Summary

- **9** dependencies scanned · **5 CRITICAL / 2 HIGH** CVEs on main (baseline) · **0 CRITICAL** cleared this cycle via auto-PR; **8 HIGH** remain (log4j 2.17.2 new CVEs + mysql + transitive protobuf)
- **Supply-chain:** typosquatted `com.fastxml.jackson.core:jackson-databind` **REMOVED** ✓ · untrusted HTTP mirror still present (gate BLOCK)
- **Tests:** 2 / 2 passed on fix branch · build clean (`mvn test` exit 0)
- **Gate outcome:** BLOCK — 8 unresolved HIGH CVEs + 1 supply-chain BLOCK; 3 required actions documented
- **PR:** [#25 — fix\(deps\): batch CVE remediation](#) · `fix/depSCAN-20260612-064614` → `main` · state: **open**
- **Projected score after full remediation:** 98 / 100 (Grade A) — two additional bumps + HTTP repo removal

Top Risks — Ranked

#	Coordinate	Risk Score	Band	Top CVE / Issue	Status
1	org.apache.logging.log4j:log4j-core	8.4	CRITICAL	CVE-2021-44228 CVSS 10.0	Bumped → 2.17.2 on PR; new CVE-2026-34480 needs 2.25.4
2	org.apache.logging.log4j:log4j-api	8.4	CRITICAL	CVE-2021-44228 CVSS 10.0	Bumped → 2.17.2 on PR; needs 2.25.4
3	com.fasterxml.jackson.core:jackson-databind	7.8	HIGH	CVE-2019-14379 CVSS 9.8	Bumped → 2.15.4 ✓ (MEDIUM CVE-2023-35116 remains, non-blocking)
4	com.fastxml.jackson.core:jackson-databind	—	CRITICAL	TYPOSQUAT supply-chain	REMOVED ✓
5	com.google.guava:guava	6.0	HIGH	CVE-2018-10237 CVSS 5.9	Bumped → 32.1.3-jre ✓ all CVEs cleared
6	mysql:mysql-connector-java	3.1	MEDIUM	GPL-2.0 + CVE-2023-22102 HIGH	Deferred — human decision required (GPL + new HIGH CVE)
7	commons-io:commons-io	2.5	LOW	Outdated (2.4)	Bumped → 2.15.1 ✓
8	org.apache.commons:commons-lang3	2.5	LOW	Outdated (3.4)	Bumped → 3.14.0 ✓ (CVE-2025-48924 MEDIUM advisory remains)
9	org.junit.jupiter:junit-jupiter	1.7	LOW	Outdated (5.10.2)	Test scope; deferred

Remediation Activity — 2026-06-12

Dependency	old → new	CVEs Cleared	PR	Status
log4j-core	2.14.1 → 2.17.2	CVE-2021-44228 (10.0), CVE-2021-45046 (9.0), CVE-2021-44832, CVE-2021-45105	#25	open — blocked on CVE-2026-34480; needs

2.25.4

log4j-api	2.14.1 → 2.17.2	CVE-2021-44228 (10.0)	#25	open — needs 2.25.4
jackson-databind	2.9.8 → 2.15.4	CVE-2019-14379 (9.8), CVE-2019-14540 (9.8), CVE-2020-36518, CVE-2022-42003, CVE-2019-12384	#25	open ✓ CVEs cleared
guava	24.1.1-jre → 32.1.3-jre	CVE-2018-10237 (5.9), CVE-2020-8908, CVE-2023-2976	#25	open ✓ CVEs cleared
commons-io	2.4 → 2.15.1	no active CVEs; security backlog	#25	open ✓
commons-lang3	3.4 → 3.14.0	no active CVEs; maintenance	#25	open ✓
com.fastxml.jackson.core:jackson-databind	2.9.8 → REMOVED	supply-chain typosquat eliminated	#25	open ✓

Deferred (human follow-up required)

Coordinate	Reason	Recommended Action
mysql:mysql-connector-java:8.0.30	GPL-2.0 license + CVE-2023-22102 (HIGH 8.3) + transitive protobuf-java CVEs	Replace with <code>com.mysql:mysql-connector-j:9.1.0</code> (GPL-2.0 classpath exception, CVE resolved)
log4j-core/api 2.17.2 → 2.25.4	CVE-2026-34480 (HIGH 7.5) discovered on 2.17.2	Stage 3 re-run will handle; or update version in PR #25
HTTP repository <code>internal-untrusted-mirror</code>	Plain HTTP = supply-chain BLOCK per policy	Remove the <code><repository></code> block from pom.xml

Supply-Chain Findings

Type	Coordinate / ID	Detail	Action	Status
TYPOSQUAT	com.fastxml.jackson.core:jackson-databind	Impersonates com.fasterxml; non-existent on Central	Removed	CLEARED ✓
UNTRUSTED_REPO	internal-untrusted-mirror	<code>http://insecure-mirror.example.net/maven2</code> — plain HTTP, no TLS	Remove <code><repository></code> block	BLOCKING

Supply-chain BLOCK: The pom.xml HTTP repository `http://insecure-mirror.example.net/maven2` remains declared and triggers an automatic supply-chain BLOCK regardless of whether artifacts were resolved from it. Remove or replace with an HTTPS-verified mirror.

Gate Verdict — Stage 4

Check	Result	Detail
<code>mvn test</code>	PASS	2 / 2 tests passed · exit 0
OWASP CVE scan	FAIL	8 unresolved HIGH CVEs (zero-tolerance threshold)
Supply-chain audit (Grype)	FAIL	Untrusted HTTP repository in pom.xml
Aggregate	BLOCK	All three checks must pass to merge

Gate review posted: [PR #25 review](#)

Health Score Breakdown

Factor	Baseline (main)	After PR #25	Fully Remediated (projected)
CRITICAL CVEs (−15 each)	5 × −15 = −75	0 × −15 = 0	0
HIGH CVEs (−8 each)	2 × −8 = −16	8 × −8 = −64	0
MEDIUM CVEs (−2 each)	5 × −2 = −10	4 × −2 = −8	1 × −2 = −2
Supply-chain BLOCK (−10 each)	2 × −10 = −20	1 × −10 = −10	0
Outdated major-version (−3 each)	3 × −3 = −9	1 × −3 = −3	0
Score	0 / 100 (D)	15 / 100 (D)	98 / 100 (A)

Trend: 0 → 15 (+15). Original Log4Shell/Jackson CRITICAL chain fully cleared. New HIGH CVEs surfaced in log4j 2.17.2 (needs 2.25.4) and mysql (CVE-2023-22102, no pre-existing fix at time of PR). One more pipeline run targeting these three items projects the score to 98.

Required Actions — Ordered by Priority

#	Action	Blocking?	Effort	Candidate for Auto-Remediation?
1	Upgrade log4j-core + log4j-api to 2.25.4	Yes (Check 2)	Low — version bump	Yes — Stage 3
2	Replace mysql-connector-java (GPL + CVE-2023-22102)	Yes (Check 2)	Medium — legal + coordinate change	Partial — human approval required
3	Remove HTTP repository from pom.xml	Yes (Check 3)	Low — delete <code><repository></code> block	Yes — Stage 3
4	Upgrade commons-lang3 to 3.18.0 (CVE-2025-48924 MEDIUM)	No	Low	Yes

Tests

- Tests: **2 / 2 passed** on fix branch (`fix/depSCAN-20260612-064614`)
- Test coverage: below 80% line threshold (JaCoCo `mvn verify` fails by design — intentional demo constraint; gate uses `mvn test` only, not `verify`)

Trend vs. Previous Run

- Health score: **0 → 15 (Δ +15)**
- CRITICAL CVEs resolved this cycle: **5** (Log4Shell chain + Jackson deserialization RCE)
- HIGH CVEs resolved: **2** (original jackson/guava)
- New HIGH CVEs surfaced: **8** (log4j 2.17.2 XmlLayout CVEs + mysql + transitive protobuf)
- Supply-chain: typosquat **cleared**, HTTP mirror **still blocking**
- PR opened: **#25** (open, gate: BLOCK)

Stakeholder Summary

State of supply-chain hygiene — 2026-06-12: The most critical threat — Log4Shell (CVE-2021-44228, CVSS 10.0) live in the billing service — has been auto-remediated along with 12 additional CVEs across Jackson, Guava, and utility libraries. The typosquatted supply-chain implant (`com.fastxml.jackson.core`) has been removed. The auto-generated PR #25 is open but currently blocked by three items the pipeline flagged in Stage 4: log4j 2.17.2 carries two new 2025–2026 HIGH CVEs (fix: 2.25.4), mysql-connector-java carries a HIGH CVE with no available fix on the GPL-licensed version (human replacement decision required), and a plain-HTTP Maven mirror in pom.xml triggers a supply-chain policy block. A follow-up pipeline run after addressing these three items projects the health score to 98/100 (Grade A).

Appendix — Artifact Inventory

Artifact	Path	Stage
Dependency scan	depscan-report.json	1
Risk score backlog	depscan-risk-report.json	2
CVE findings report	depscan-reports/CVE-Report.md	1
Risk scoring report	depscan-reports/Risk-Scoring-Report.md	2
Remediation PR	github.com/.../pull/25	3
SBOM (CycloneDX)	target/sbom.cdx.json	3
Gate verdict	depscan-verdict.md	4
Gate PR review	PR #25 review	4
This report	depscan-reports/Audit-Trail-Report.md	5

Demo Script — Live Readiness

Pre-flight Checklist

- ☐ Java 17+ on PATH: `java -version`
- ☐ Maven 3.8+ on PATH: `mvn -version`
- ☐ Syft on PATH (SBOM): `syft version`
- ☐ Gripe on PATH (supply-chain): `gripe version`
- ☐ GitHub token valid: `gh auth status`
- ☐ Repo at known vulnerable commit: `git log --oneline -1` shows `61ed8c3`
- ☐ `depscan-report.json` absent (fresh scan): `ls depscan-report.json 2>/dev/null || echo "clean"`

Demo Narrative (5 beats)

Beat 1 — Show the problem Open `pom.xml` . Highlight `log4j-core:2.14.1` . State: "This is Log4Shell — CVSS 10, unauthenticated RCE, live in the billing service."

Beat 2 — Detect

```
# Run Stage 1+2 scan
/depscan-pipeline . --mode full
```

Watch the risk report surface: 5 CRITICAL CVEs, ranked backlog, Log4Shell at the top with billing-service context.

Beat 3 — Score Show `depscan-risk-report.json` — log4j-core at risk score 8.4, rationale: "JNDI injection in DiscountCalculator billing path." Point out the typosquat at rank #4.

Beat 4 — Auto-fix Stage 3 opens PR #25 automatically — show the fix table: 7 changes in one PR, changelog with CVE IDs, typosquat removed.

Beat 5 — Gate Stage 4 posts the BLOCK verdict to the PR. Explain: "The gate found new CVEs in log4j 2.17.2 — the pipeline didn't stop at the first fix, it kept scanning. Re-run with 2.25.4 + mysql fix to reach Grade A."

Rollback Note

To reset the demo repo to the vulnerable baseline:

```
git checkout main
git reset --hard 61ed8c3140d76e3a19a88954e834d39c9f7635fb
rm -f depscan-report.json depscan-risk-report.json depscan-verdict.md
rm -f target/sbom.cdx.json
# Close or delete PR #25 on GitHub if re-running Stage 3 cleanly
```

Auto-generated by Dependency & Supply-Chain Pipeline — Stage 5 (Audit Trail). Run: 2026-06-12T07:05:00Z. PR: [#25](#). Gate: BLOCK.